

Εργασία Εξαμήνου: Man-in-the-Middle Attack με ARP Spoofing, DNS Spoofing, Certificate Manipulation, Session Hijacking και DHCP Starvation

Χειμερινό Εξάμηνο 2025-2026

Διδάσκων: Α.Φακής

Σκοπός Εργασίας

Η εργασία αυτή έχει στόχο να εξοικειώσει τους φοιτητές με τις τεχνικές Man-in-the-Middle (MITM) επιθέσεων, εστιάζοντας σε ARP spoofing, DNS spoofing, την παραβίαση HTTPS μέσω rogue certificate injection, την κλοπή session cookies και την κατάληψη network infrastructure μέσω DHCP starvation. Οι φοιτητές θα υλοποιήσουν μια προσομοιωμένη επίθεση σε ελεγχόμενο περιβάλλον εικονικών μηχανών, θα αναλύσουν τα πακέτα με το Wireshark και θα προτείνουν μέτρα αντιμετώπισης, κατανοώντας τη σημασία του TLS, των network defenses και των αδυναμιών των network protocols.

Η εργασία συνδυάζει hands-on εφαρμογές και κριτική αντανάκλαση, ενώ απαιτεί μοναδικά logs, screenshots και προσωπικές εμπειρίες troubleshooting που καθιστούν δύσκολη την αυτοματοποιημένη παραγωγή μέσω τεχνητής νοημοσύνης.

Περιβάλλον Εργασίας

Εργαλεία:

- Kali Linux (attacker machine)
- Ubuntu (victim machine)
- pfSense ή παρόμοιο (router/gateway)
- VirtualBox, VMware ή GNS3 για virtualization

Software:

- Bettercap για ARP/DNS spoofing
- Wireshark για packet analysis
- Apache ή Nginx για fake server
- SET (Social Engineering Toolkit) για website cloning
- OpenSSL για certificate generation
- Scapy ή hping3 για packet crafting και SYN flood

Network Setup:

- Εικονικό δίκτυο με 3 VMs:
 - Attacker: 192.168.1.50
 - Victim: 192.168.1.100
 - Gateway: 192.168.1.1
- Προτεινόμενο: Host-Only Network (isolated) ή Internal Network
- Για Φάση 6 (DHCP): MONO Host-Only!

Βήματα Εργασίας

Φάση 1: ARP Spoofing & Packet Capture

Στόχος: Εκτελέστε ARP spoofing για να πείσετε το victim ότι η MAC address του gateway είναι η δική σας MAC address, καθιστώντας σας MITM. Capture-άρετε το traffic με Wireshark και επιβεβαιώστε την επίθεση.

Ενέργειες:

1. Στο Kali Linux, εκκινήστε το Bettercap και εκτελέστε ARP cache poisoning targeting το victim machine. Στόχος: Να αντικαταστήσετε την MAC address του gateway στο ARP table του victim με τη δική σας.
2. Στο victim, πλοηγηθείτε σε ένα μη κρυπτογραφημένο website (π.χ. <http://httpbin.org/forms/post>) και εισάγετε dummy credentials (πιο συγκεκριμένα εισάγετε το icsd σας ως username καθώς και ένα δικό σας password). Βγάλτε διαφορετικά screenshot για κάθε μέλος της ομάδας.
3. Στο Wireshark (attacker machine), ξεκινήστε capture με κατάλληλο filter για να δείτε ARP και HTTP traffic.

4. Εντοπίστε ARP replies που αντιστοιχίζουν την IP του gateway με το MAC address του attacker. Αυτό είναι απόδειξη ότι το ARP cache του victim έχει «μολυνθεί» (poisoned) με ψεύτικη MAC address για το gateway.
5. Εντοπίστε τα HTTP POST data με τα plaintext credentials.

Παραδοτέα Φάσης 1:

- Screenshot του Wireshark που δείχνει τα ARP replies
- Screenshot του HTTP POST request με τα credentials
- Σύντομη περιγραφή (100 λέξεις): Τι παρατηρήσατε στα ARP packets και πώς επιβεβαιώσατε την επίθεση
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.

Φάση 2: DNS Spoofing & Website Cloning με SET

Στόχος: Redirect-άρετε το victim σε cloned fake site μέσω DNS spoofing χρησιμοποιώντας το Social Engineering Toolkit για realistic website cloning.

Ενέργειες:

1. Στο Kali Linux, χρησιμοποιήστε το Social Engineering Toolkit (SET) για να δημιουργήσετε ένα ακριβές clone μιας γνωστής ιστοσελίδας (Προτείνεται να επιλέξετε simple login page (όχι full site π.χ. login τραπεζικής σελίδας, κάποια σελίδα login κάποια σχολής 😊)). Το SET έχει built-in web cloning functionality που αντιγράφει οποιαδήποτε σελίδα τοπικά με όλα τα στυλ και scripts.

Προσοχή:

- Πολλά modern sites έχουν anti-cloning protections.
- Τα JavaScript dependencies μπορεί να αποτύχουν
- Αρκετές σελίδες περιέχουν Content Security Policy (CSP) headers
- Κάποια εξωτερικά resources ενδέχεται να μην φορτώνουν σωστά.

Σε περίπτωση που εμφανίζεται πρόβλημα δημιουργήστε ένα απλό clone της login σελίδας. Αναμένετε ότι θα χρειαστεί manual τροποποίηση του HTML για να λειτουργήσει σωστά (αφαίρεση scripts, διόρθωση links). Εξηγήστε στο βίντεο τα προβλήματα που αντιμετωπίσατε αλλά και εν συντομία τις αλλαγές που κάνατε.

2. Ρυθμίστε το SET να καταγράφει τα credentials που εισάγονται στο cloned site.
3. Με το Bettercap, ενεργοποιήστε DNS spoofing για να redirect-άρετε συγκεκριμένο domain name (π.χ. gmail.com ή bankofexample.com) στη διεύθυνση IP του attacker. (Το Bettercap θα intercept-άρει DNS queries από το victim και θα στείλει fake DNS responses πριν φτάσει η legitimate απάντηση από τον real DNS server)
4. Στο victim, προσπαθήστε να επισκεφθείτε το targeted domain.
5. Παρατηρήστε ότι εμφανίζεται το cloned site (αλλά με HTTP αντί HTTPS στο URL bar).

Προσοχή:

Αν ο χρήστης πληκτρολογήσει gmail.com ακόμα και μετά από DNS spoofing, ένας σύγχρονος browser θα υποχρεώσει το redirect σε https, καθώς οι περισσότεροι έχουν hardcoded HTTPS για major sites. Σε μια τέτοια περίπτωση, χρησιμοποιήστε ένα domain που ΔΕΝ είναι στο HSTS preload list ή δημιουργήστε typosquatted domain (π.χ. gmai1.com αντί gmail.com). **Στα πλαίσια της εκφώνησης, το domain που επιλέξατε και δεν προστατεύεται από HSTS, θα το αναφέρουμε ως <https://testbank-login.com>.**

Βήματα:

1. Ελέγξτε αν το target domain έχει HSTS με: `curl -I -L https:// testbank-login.com`
2. Αν βλέπετε 'Strict-Transport-Security', επιλέξτε άλλο domain
3. Δημιουργήστε το clone με SET
4. Ρυθμίστε DNS spoofing για το chosen domain
6. Εισάγετε test credentials στο fake site.
7. Capture-άρετε τα plaintext credentials στο Wireshark και επιβεβαιώστε ότι καταγράφηκαν στο SET.

Παραδοτέα Φάσης 2:

- Screenshot του SET κατά το website cloning process
- Screenshot του cloned website στο browser του victim
- Log files από το Bettercap που δείχνουν DNS responses
- Screenshot του Wireshark με το DNS spoofing traffic
- Αρχείο με τα captured credentials από το SET
- Screenshot που δείχνει την απουσία HTTPS indicator
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.
- Σύντομη περιγραφή (200 λέξεις): Πώς λειτούργησε το DNS spoofing, γιατί το victim δεν είδε security warning, και πόσο realistic ήταν το cloned site

Φάση 3: HTTPS Downgrade με SSL Stripping

Στόχος: Παρακάμψτε την HTTPS προστασία με SSL stripping για να downgrade-άρετε encrypted connections σε HTTP.

Ενέργειες:

1. Ενώ τρέχει το ARP και DNS spoofing, ενεργοποιήστε HTTP proxy με SSL stripping capability στο Bettercap.
2. Δοκιμάστε την επίθεση σε τρεις κατηγορίες targets:

Easy Target (HTTP site):

- Επισκεφτείτε `http://httpbin.org/forms/post`
- Εισάγετε test credentials και capture το plaintext traffic

Medium Target (Vulnerable HTTPS):

- Επισκεφτείτε `testbank-login.com` από τον victim
- Παρατηρήστε αν downgrade-άρεται σε HTTP (θα δουλέψει)

Hard Target (Protected HTTPS):

- Επισκεφτείτε `https://github.com` ή `https://facebook.com`
- Παρατηρήστε ότι η επίθεση ΑΠΟΤΥΓΧΑΝΕΙ
- Εξηγήστε γιατί στο troubleshooting log

3. Capture-άρετε στο Wireshark:

- Successful SSL strip (`testbank-login.com`): HTTPS request → HTTP redirect → HTTP response
- Failed SSL strip (`GitHub`): HTTPS request → HSTS response → Browser blocks

4. Συγκρίνετε τα αποτελέσματα και εξηγήστε τις διαφορές.

Παραδοτέα Φάσης 3:

- Screenshot που δείχνουν:
 - Normal HTTPS σε protected site (padlock, HSTS)

- Successful HTTP downgrade σε vulnerable site
 - Browser warning 'Not Secure' (αυτό είναι NORMAL)
 - Failed SSL strip για protected sites
- Wireshark capture με SSL strip traffic (.pcapng)
 - Successful downgrade traffic (testbank-login.com): HTTPS request → HTTP redirect → HTTP response
 - Failed attempt με HSTS blocking (π.χ. GitHub)
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.
- Σύντομη ανάλυση (150 λέξεις):
 - Γιατί το SSL stripping λειτούργησε και ποιος ο ρόλος του MITM
 - Γιατί το testbank-login.com είναι vulnerable ενώ το GitHub όχι
 - Ο ρόλος του HSTS και browser protections

Φάση 4: Rogue Certificate Injection για HTTPS MITM

Στόχος: Δημιουργήστε και εγκαταστήστε ένα rogue CA certificate στο victim machine για να decrypt-άρετε HTTPS traffic χωρίς browser warnings.

Ενέργειες:

1. Target Selection & Reconnaissance:
 - Επιλέξτε ένα HTTPS site που ΔΕΝ έχει certificate pinning
 - Ελέγξτε με: `curl -I -L https://target-site.com | grep -i pin`
 - Αποφύγετε major sites (Google, Facebook, GitHub, banking)
 - Προτεινόμενα: Educational sites, local government, small businesses
2. Στο Kali, δημιουργήστε ένα self-signed certificate χρησιμοποιώντας OpenSSL για το domain που θα επιτεθείτε (ιδανικά το domain από την φάση 2).
3. Στήστε HTTPS server με Apache/Nginx:
 - Ρυθμίστε το προσαρμοσμένο πιστοποιητικό (target-site.crt + target-site.key)
 - Host το cloned website από τη Φάση 2
 - Διακομιστής να ακούει στη θύρα 443
4. Στο victim machine, προσομοιώστε social engineering attack: Manually εισάγετε το fake certificate στο trust store του λειτουργικού συστήματος ή του browser. Αυτό μπορεί να γίνει με:
 - Import στο certificate store του OS
 - Import μέσω browser settings (Privacy > Certificates > Import)
 - Social engineering (σε controlled environment) (bonus +0.5)
 - Αντί για manual certificate installation, δημιουργήστε realistic scenario: - Δημιουργήστε fake "security update" email - Clone legitimate certificate installation instructions - Document πώς θα μπορούσε ένας attacker να πείσει θύμα - Analyze ποια social engineering tactics θα ήταν πιο αποτελεσματικά

ΣΗΜ: Η actual certificate installation παραμένει manual για το lab
5. Διαμόρφωση MITM:
 - Βεβαιωθείτε ότι η δηλητηρίαση ARP τρέχει (από Φάση 1)
 - Πλαστογράφιση DNS: target-site.com → [IP-επιτιθέμενου]
 - Δρομολόγηση κίνησης μέσω του προσαρμοσμένου διακομιστή HTTPS
6. Εκτέλεση επίθεσης:
 - Το θύμα πλοηγείται στο https://target-site.com

- Επιβεβαιώστε: Ο φυλλομετρητής δείχνει πράσινο λουκετάκι (έμπιστη σύνδεση)
 - Εισάγετε δοκιμαστικά διαπιστευτήρια στη σελίδα σύνδεσης
7. Αποκρυπτογράφηση κίνησης:
- Ρυθμίστε το Wireshark με το ιδιωτικό κλειδί (target-site.key)
 - Αποκρυπτογράφηση TLS: Επεξεργασία > Προτιμήσεις > Πρωτόκολλα > TLS > Λίστα κλειδιών RSA
 - Προσθέστε: IP=[IP-επιτιθέμενου], Θύρα=443, Πρωτόκολλο=http, Αρχείο Κλειδιού=target-site.key
 - Καταγράψτε και αναλύστε τα αποκρυπτογραφημένα δεδομένα εφαρμογής
8. Δοκιμή σύγκρισης (εκπαιδευτική):
- Δοκιμάστε την ίδια επίθεση εναντίον του <https://github.com>
 - Παρατηρήστε: Προειδοποιήσεις πιστοποιητικού φυλλομετρητή / μπλοκάρισμα καρφίτσωματος
 - Τεκμηριώστε γιατί αποτυγχάνει

Παραδοτέα Φάσης 4:

- Στιγμιότυπο οθόνης: Διαδικασία δημιουργίας πιστοποιητικού με OpenSSL (έξοδος τερματικού)
- Στιγμιότυπο οθόνης: Πιστοποιητικό εισηγμένο στο κατάστημα πιστοποιητικών φυλλομετρητή
- Στιγμιότυπο οθόνης: Φυλλομετρητής δείχνει πράσινο λουκετάκι για my-target.com
- Στιγμιότυπο οθόνης: Αποτυχία καρφίτσωματος πιστοποιητικού για GitHub (για σύγκριση)
- Αρχείο καταγραφής Wireshark (.pcapng) με επιτυχώς αποκρυπτογραφημένη κίνηση TLS
- Στιγμιότυπο οθόνης: Wireshark εμφανίζει αποκρυπτογραφημένα δεδομένα HTTP POST σε απλό κείμενο
- Αρχεία πιστοποιητικού: my-target.crt και my-target.key (για επαλήθευση)
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.
- Τεχνική ανάλυση (250 λέξεις):
 - Εξηγήστε γιατί ο φυλλομετρητής του θύματος εμπιστεύτηκε το πλαστό πιστοποιητικό
 - Ποιος ο ρόλος του καταστήματος εμπιστοσύνης πιστοποιητικών στην επίθεση
 - Σύγκριση: Εισαγωγή πιστοποιητικού εναντίον αφαίρεσης SSL (διατηρείται κρυπτογράφηση αλλά αρπάζεται η εμπιστοσύνη)
 - Γιατί η επίθεση αποτυγχάνει σε ιστότοπους με καρφίτσωμα πιστοποιητικού (π.χ. GitHub)
 - Πραγματική εφικτότητα: Δυσκολία κοινωνικής μηχανικής για εγκατάσταση πιστοποιητικού

Φάση 5: Session Hijacking μέσω Cookie Theft

Στόχος: Κλέψτε session cookies από το victim μέσω MITM attack και χρησιμοποιήστε τα για session hijacking.

Ενέργειες:

0. ΠΡΟΑΠΑΙΤΟΥΜΕΝΟ - Cookie Visibility:

- Η κλοπή session cookies απαιτεί plaintext HTTP communication
- HTTPS κρυπτογραφεί τα cookies μέσα στο TLS tunnel → αδύνατη capture
- Χρησιμοποιήστε μία από τις παρακάτω μεθόδους:

Μέθοδος A: HTTP site

- Στόχος: Στο θύμα, συνδεθείτε στο <http://testbank-login.com/> (HTTP version) - Εισάγετε test credentials

- Στο Wireshark, φιλτράρετε: http.request

Μέθοδος B: Successful SSL Stripping

- Χρησιμοποιήστε το SSL stripping από Φάση 3
- Downgrade <https://testbank-login.com/> → HTTP
- Εισάγετε test credentials

Μέθοδος Γ: Certificate Injection

- Χρησιμοποιήστε το rogue certificate από Φάση 4
- Decrypt TLS traffic με το private key στο Wireshark
- Cookies θα είναι ορατά μετά την αποκρυπτογράφηση

1. Προετοιμασία στόχου:

- Ενώ τρέχει το ARP spoofing, εντοπίστε HTTP sites που χρησιμοποιούν cookies
- Καλός στόχος: domain που δοκιμάσατε στις προηγούμενες φάσεις (HTTP login page)
- Εναλλακτικά: httpbin.org/cookies (για δοκιμή)

2. Καταγραφή cookies σε plaintext:

- Στο θύμα, συνδεθείτε στο testbank-login.com με test credentials
- Στο Wireshark, φιλτράρετε HTTP traffic: http.request
- Εντοπίστε Cookie headers σε HTTP requests: Cookie: PHPSESSID=abc123xyz; path=/

3. Εξαγωγή session cookies:

- Αντιγράψτε τα session cookie values από το Wireshark
- Σημειώστε: Cookie name, value, domain, path

4. Session hijacking:

- Στον επιτιθέμενο, ανοίξτε τον ίδιο browser
- Χρησιμοποιήστε developer tools ή extension (Cookie Editor) Εισάγετε τα stolen cookies στο browser σας
- Πλοηγηθείτε στο testbank-login.com

5. Επιβεβαίωση hijacking:

- Επιβεβαιώστε ότι είστε συνδεδεμένος χωρίς να εισάγετε credentials
- Αποκτήστε πρόσβαση στο authenticated session του θύματος

Παραδοτέα Φάσης 5:

- Στιγμιότυπο οθόνης: Wireshark με highlighted HTTP Cookie headers
- Στιγμιότυπο οθόνης: Cookie injection στον browser επιτιθέμενου (Developer Tools)
- Στιγμιότυπο οθόνης: Επιτυχές session hijacking (logged in ως θύμα χωρίς credentials)
- Αρχείο καταγραφής Wireshark (.pcapng) με captured cookie traffic
- Στιγμιότυπο οθόνης: Αποτυχία επίθεσης με Secure/HttpOnly cookies (για εκπαιδευτική σύγκριση)
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.

Φάση 6: DHCP Starvation & Rogue DHCP Server

Στόχος: Κατακτήστε τον έλεγχο του network infrastructure μέσω DHCP attacks και γίνετε το default gateway για όλα τα νέα devices

Ενέργειες:

1. DHCP Network Analysis:

- Ανακαλύψτε τον legitimate DHCP server: `nmap --script broadcast-dhcp-discover`
- Αναλύστε DHCP lease pool: IP range, DNS servers, gateway
- Καταγράψτε current network configuration

2. DHCP Starvation Attack:

- Εξαντλήστε το DHCP lease pool του legitimate server

- `dhcpcstarv -i eth0 -s [start-IP] -e [end-IP]`
- Σκοπός: Κανένα νέο device να μην παίρνει IP από legitimate server

3. Rogue DHCP Server Setup:

- Στήστε δικό σας DHCP server με malicious configuration:
 - **Gateway:** [attacker-IP] (εσείς γίνεστε gateway!)
 - **DNS:** [attacker-IP] (εσείς γίνεστε DNS server!)
 - **IP Pool:** Overlapping με legitimate network
- dnsmasq configuration για DHCP + DNS serving

4. Victim Device Testing:

- Νέο device συνδέεται στο network
- Λαμβάνει malicious DHCP lease από εσάς
- Όλο το traffic του περνάει μέσω σας (automatic MITM!)

5. DNS Hijacking Integration:

- Συνδυάστε με DNS spoofing από Φάση 2
- Redirect popular domains σε malicious servers
- Παράδειγμα: google.com → [your-fake-site]

6. Traffic Analysis:

- Capture όλο το traffic από compromised devices
- Σύγκριση: Manual MITM (ARP) vs Automatic MITM (DHCP)
- Τεκμηριώστε την αποτελεσματικότητα της επίθεσης

ΠΡΟΕΙΔΟΠΟΙΗΣΗ:

- ⚠️ Η επίθεση αυτή μπορεί να διακόψει network services
- ⚠️ Εκτελέστε ΜΟΝΟ σε isolated virtual network
- ⚠️ Snapshot τις VMs πριν ξεκινήσετε

Safety measures:

1. Χρησιμοποιήστε host-only network στο VirtualBox
2. Disable network adapters που συνδέονται σε real network
3. Κρατήστε backup του DHCP configuration

Παραδοτέα Φάσης 6:

- Στιγμιότυπο οθόνης: DHCP discovery scan (legitimate server info)
- Στιγμιότυπο οθόνης: DHCP starvation attack σε εξέλιξη
- Στιγμιότυπο οθόνης: Rogue DHCP server configuration (dnsmasq.conf)
- Στιγμιότυπο οθόνης: Victim device παίρνει malicious DHCP lease
- Στιγμιότυπο οθόνης: Automatic traffic interception (χωρίς manual ARP)
- Wireshark capture: DHCP conversation + hijacked traffic
- Στιγμιότυπο οθόνης: DNS hijacking μέσω rogue DHCP
- Σύντομο demonstration clip που θα συμπεριληφθεί στο τελικό video.
- Τεχνική ανάλυση (300-400 λέξεις):
 - ο Πώς το DHCP starvation εξαντλεί τον legitimate server
 - ο Γιατί τα devices εμπιστεύονται τον πρώτο DHCP που απαντά
 - ο Σύγκριση ARP spoofing vs DHCP hijacking για MITM setup
 - ο Γιατί αυτή η επίθεση είναι πιο scalable από ARP spoofing
 - ο Defense mechanisms: DHCP snooping, port security, 802.1X

- Real-world impact: Πώς attackers κατακτούν corporate networks

Φάση 7: Ανάλυση Επιθέσεων & Μέτρα Άμυνας

Στόχος: Αναλύστε τα αποτελέσματα όλων των φάσεων και προτείνετε ρεαλιστικά μέτρα άμυνας.

Ενέργειες:

1. Εξετάστε προσεκτικά όλα τα Wireshark captures (.pcapng files) για:
 - ARP poisoning indicators (duplicate replies, MAC address conflicts)
 - DNS spoofing indicators (fake DNS responses)
 - TLS handshake patterns (successful/failed connections)
 - Session cookies και authentication tokens
 - Decrypted HTTPS streams
2. Προσδιορίστε τι πήγε στραβά κατά τη διάρκεια των επιθέσεων σας:
 - Blocked από HSTS;
 - Certificate pinning;
 - Secure cookies;
 - Άλλα security mechanisms;
3. Προτείνετε τουλάχιστον 6 συγκεκριμένα μέτρα άμυνας και εξηγήστε λεπτομερώς πώς το καθένα μπλοκάρει ή μετριάζει τις επιθέσεις που υλοποιήσατε. Παραδείγματα:
 - HSTS (HTTP Strict Transport Security)
 - Certificate Pinning
 - DNSSEC
 - Static ARP entries / Dynamic ARP Inspection
 - VPN encryption (IPsec/TLS)
 - Secure & HttpOnly cookie flags
 - IPsec ESP για traffic encryption

Παραδοτέα Φάσης 7:

- Ολοκληρωμένη ανάλυση (500-600 λέξεις) που περιλαμβάνει:
 - Τι είδατε σε κάθε επίθεση (ARP, DNS, TLS, Cookies, DHCP)
 - Ποια security mechanisms σας εμπόδισαν και πώς
 - 6 defenses με εξήγηση για το πώς αντιμετωπίζουν τις επιθέσεις
 - Πώς θα εφαρμόζατε αυτά τα μαθήματα σε real-world scenario (π.χ. campus WiFi, εταιρικό δίκτυο)

Τελικά Παραδοτέα

1. Βίντεο Demonstration (8-12 λεπτά)

Δημιουργήστε video demo που δείχνει **σε κάθε φάση** πως καταφέρατε να εκτελέσετε την επίθεση. Τι σας δούλεψε (και γιατί ήταν επιτυχής η επίθεση) ή τι δεν δούλεψε (και γιατί απέτυχε η επίθεση):

- Εκτέλεση ARP και DNS spoofing
- Website cloning με SET
- Browser screenshots (HTTP vs HTTPS indicators)
- Live Wireshark captures κατά την επίθεση
- Certificate installation process
- Session hijacking σε δράση
- Σύντομη narration για κάθε φάση (τι κάνετε και γιατί)

Σημείωση: Το video πρέπει να είναι δικό σας recording, όχι screen captures από tutorials. Η narration πρέπει να είναι με δική σας φωνή και να εξηγεί τι συμβαίνει.

2. Technical Artifacts

- Όλα τα .pcapng files από το Wireshark (μία για κάθε φάση, 6 συνολικά)
- Log files από το Bettercap
- Αρχείο credentials.txt από το SET
- Screenshot του fake certificate στο trust store
- Screenshot του stolen cookie injection
- Screenshot του DHCP starvation attack
- Screenshot του rogue DHCP server configuration
- Φωτογραφίες του network setup (VMs, network topology)

3. Γραπτή Αναφορά (1400-1700 λέξεις)

Η αναφορά πρέπει να περιλαμβάνει:

Εισαγωγή:

- Σκοπός της εργασίας
- Network setup και tools που χρησιμοποιήσατε
- Overview των επιθέσεων που υλοποιήσατε

Τεχνική Υλοποίηση:

- Περιγραφή κάθε φάσης με τεχνικές λεπτομέρειες
- Screenshots και references στα artifacts
- Troubleshooting: Τι προβλήματα αντιμετωπίσατε και πώς τα λύσατε

Ανάλυση & Αντανάκλαση:

- Τι είδατε στα πακέτα (πρωτόκολλα, headers, payloads)
- Ποια security mechanisms εμπόδισαν την επίθεση
- Σύγκριση με protocol vulnerabilities από το μάθημα (IKE, TCP, ESP)

- Η σημασία του MITM position για όλες τις επιθέσεις

Defenses:

- 6 συγκεκριμένα μέτρα προστασίας
- Τεχνική εξήγηση για το πώς το καθένα αντιμετωπίζει την επίθεση
- Real-world applicability
- Ποια defenses είναι πιο effective και γιατί

Συμπεράσματα:

- Τι μάθατε από την εργασία
- Σημασία των network defenses και encryption στην πράξη
- Reflections για ethical hacking

4. Troubleshooting Log (Υποχρεωτικό)

Δημιουργήστε ένα structured log που καταγράφει:

- Τι απέτυχε κατά την υλοποίηση (π.χ. HSTS block, certificate warning, wrong DHCP lease configuration, SSL strip failure)
- Τι δοκιμάσατε για να λύσετε το πρόβλημα
- Τελική λύση ή workaround
- Τι μάθατε από κάθε πρόβλημα

Μορφή: Πίνακας με στήλες: Problem | Attempted Solutions | Final Solution | Lessons Learned

Τουλάχιστον 5 entries συνολικά από διαφορετικές φάσεις.

5. Extra Challenge (Για ομάδα 3 ατόμων)

SYN Flood Attack (5%)

- Υλοποιήστε SYN flood attack με spoofed source IPs χρησιμοποιώντας hping3 ή Scapy
- Δείξτε τον dual effect: DoS στο victim και SYN+ACK flooding σε spoofed IPs (όπως συζητήθηκε στο μάθημα)
- Capture-άρετε το traffic στο Wireshark και δείξτε τα half-open connections
- Προτείνετε defenses (SYN cookies, rate limiting)
- Παραδοτέα: .pcapng file, σύντομο demonstration clip, screenshot του attack, 200-word analysis

Defense Implementation (10%)

- Υλοποιήστε 2 από τα 6 defenses που προτείνετε
 - Configure HTTPS Strict Transport Security headers σε Apache/Nginx
 - Setup secure cookie flags (Secure, HttpOnly, SameSite) σε test web app
 - Configure browser certificate warnings/validation
 - Implement basic firewall rules για ARP protection
 - Setup network monitoring για ARP anomaly detection
- Δείξτε ότι οι επιθέσεις πλέον αποτυγχάνουν

- Παραδοτέα: Configuration files, screenshots πριν/μετά, σύντομο demonstration clip, 300-word explanation

HTTP Traffic Manipulation (10%)

- Intercept και modify HTTP responses σε real-time
- Inject malicious JavaScript code σε web pages
- Replace images με malicious content κατά τη μεταφορά
- Modify HTTP headers για additional attacks (XSS, redirects)
- Δείξτε successful content injection με browser screenshots
- Παραδοτέα:
 - Wireshark capture με modified content
 - Screenshots πριν/μετά την manipulation
 - Σύντομο demonstration clip
 - 250-word analysis of impact

Αξιολόγηση

Τεχνική Υλοποίηση (60%)

- Φάση 1: ARP Spoofing (8%)
- Φάση 2: DNS Spoofing & Website Cloning (9%)
- Φάση 3: SSL Stripping (8%)
- Φάση 4: Certificate Injection (10%)
- Φάση 5: Session Hijacking (9%)
- Φάση 6: DHCP Starvation (10%)
- Φάση 7: Ανάλυση Επιθέσεων (6%)

Γραπτή Αναφορά (25%) (διαμοιράζεται ισόποσα στα ερωτήματα)

- Σαφήνεια και οργάνωση (8%)
- Τεχνική ακρίβεια (10%)
- Ανάλυση defenses (7%)

Αυθεντικότητα & Κριτική Σκέψη (15%)

- Unique screenshots και logs (5%)
- Troubleshooting log με personal errors (5%)
- Critical reflection και real-world applicability (5%)

Bonus (έως +5%)

- Προαιρετικά challenges

Προθεσμίες & Milestones

Για να αποφύγετε το last-minute stress και να εξασφαλίσετε καλύτερη κατανόηση, προτείνονται τα εξής milestones:

Milestone 1 (Εβδομάδα 1-2): Φάσεις 1-2 - Submit ARP spoofing και DNS spoofing screenshots **Milestone 2 (Εβδομάδα 3-4):** Φάσεις 3-4 - Submit SSL stripping και certificate screenshots **Milestone 3 (Εβδομάδα 5-6):** Φάσεις 5-6 - Submit cookie theft και DHCP starvation demos **Τελική Παράδοση (Εβδομάδα 7-8):** Ολοκλήρωση όλων των παραδοτέων

Τα milestones δεν βαθμολογούνται ξεχωριστά, αλλά βοηθούν στην οργάνωση και επιτρέπουν feedback κατά τη διάρκεια της εργασίας.

Σημαντικές Επισημάνσεις

Anti-AI Strategy

Η εργασία έχει σχεδιαστεί για να απαιτεί:

- Μοναδικά logs από το δικό σας environment (IP addresses, timestamps, MAC addresses, sequence numbers)
- Personal troubleshooting experiences που δεν μπορούν να προβλεφθούν
- Screenshots με το δικό σας desktop environment
- Video με δική σας narration και screen recording
- Κριτική ανάλυση των δικών σας αποτελεσμάτων και παρατηρήσεων κατά την υλοποίηση

Η χρήση AI για παραγωγή fake logs ή generic reports θα είναι προφανής και θα οδηγήσει σε σοβαρή μείωση βαθμολογίας.

- Recommended resources: Bettercap documentation, SET documentation, Wireshark User Guide, Scapy documentation, OWASP Testing Guide

Troubleshooting Tips

- **ARP spoofing:** Αν δεν λειτουργεί, ελέγξτε IP forwarding (`echo 1 > /proc/sys/net/ipv4/ip_forward`) και firewall rules
- **SSL stripping:** Αν αποτύχει λόγω HSTS, δοκιμάστε non-HSTS site ή typosquatted domain (π.χ. `bannk.com` αντί για `bank.com`), οπότε σε αυτήν την περίπτωση η επίθεση θα λειτουργήσει εάν ο χρήστης κάνει typo κατά την πληκτρολόγηση του domain (το οποίο είναι αποδεκτό στα πλαίσια της εργασίας).